Criptografía y Certificados Digitales en la Práctica

Objetivo: Comprender la función de los certificados digitales, el rol de las Autoridades de Certificación (CA) y verificar criptográficamente una cadena de confianza implementando HTTPS en un dominio propio usando Let's Encrypt.

Parte 1: Fundamentos Teóricos (PKI y Estándar X.509)

Antes de configurar el servidor, investiga y responde:

1. **Definición básica:** ¿Qué es exactamente un certificado digital X.509 y qué problema fundamental de criptografía asimétrica resuelve? (Pista: Piensa en el ataque *Man-in-the-Middle*).
2. **El Rol de la CA:** ¿Qué es una Autoridad de Certificación (CA) y por qué los navegadores confían en ellas para validar la identidad de un sitio web?
3. **Jerarquía:** Define las diferencias y responsabilidades entre un Certificado Raíz (*Root CA*), un Certificado Intermedio y un Certificado de Entidad Final (*End-Entity/Leaf Certificate*).
4. **Ciclo de vida:** ¿Qué es una Lista de Revocación de Certificados (CRL) y qué es OCSP? ¿Por qué son necesarios incluso antes de que un certificado expire?

Parte 2: Despliegue Práctico (Let's Encrypt)

Instala un servidor web (Nginx/Apache) en tu servidor y asocia un dominio propio. Luego, utiliza Certbot para solicitar un certificado a Let's Encrypt.

1. **Mecanismo de validación:** Let's Encrypt utiliza el protocolo ACME. ¿Qué método de validación o "desafío" (*challenge*) utilizaste (ej. HTTP-01 o DNS-01) y cómo demostró este proceso a la CA que tú tienes el control real sobre ese dominio?
2. **Duración de la confianza:** Let's Encrypt emite certificados con una validez máxima de 90 días, a diferencia de las CAs comerciales clásicas que emitían por 1 o 2 años. Desde el punto de vista de la seguridad, ¿cuáles son las dos principales ventajas de tener una vida útil tan corta?
3. **Automatización:** ¿Por qué la automatización (ej. un cron job de Certbot) es un requisito casi obligatorio bajo el modelo de Let's Encrypt?

Parte 3: Análisis de la Cadena de Confianza y Criptografía

Una vez que tu sitio esté funcionando por HTTPS, utiliza tu navegador web (clic en el candado > Detalles del certificado) o la terminal (`openssl s_client -connect tudominio.com:443` y `openssl x509 -in cert.pem -text -noout`) para responder:

1. **Inspección de campos:** Revisa tu certificado de entidad final y detalla:
    - ¿Quién es el *Issuer* (Emisor) y quién es el *Subject* (Sujeto)?
    - ¿Qué algoritmo de clave asimétrica se está utilizando para la clave pública (ej. RSA, ECDSA) y de qué tamaño es la clave (ej. 2048 bits, secp256r1)?

2. **Trazando la ruta (Chain of Trust):** Identifica la ruta de certificación completa de tu dominio. Escribe la cadena exacta de firmas desde tu certificado *Leaf* hasta el certificado *Root* en el que confía tu navegador (ej. ISRG Root X1).
3. **Seguridad del ecosistema:** ¿Por qué el certificado de tu sitio web fue firmado por una CA Intermedia (ej. Let's Encrypt R3) y no directamente por la clave privada de la CA Raíz? (Investiga sobre el almacenamiento *offline* de las claves raíz).
4. **Validación matemática:** Explica el proceso criptográfico exacto que realiza tu navegador cuando recibe el certificado de tu servidor. ¿Cómo utiliza la clave pública de la CA Intermedia para verificar la "Firma Digital" (*Signature*) de tu certificado y asegurar que no ha sido alterado?
5. **Almacén de confianza (Trust Store):** ¿De dónde saca tu sistema operativo o navegador la clave pública de la CA Raíz para terminar de validar la cadena? Busca el certificado raíz de Let's Encrypt en el almacén de certificados de tu propio sistema operativo y documenta su presencia.